

TUMBUH

Architecture Diagram dan Rancangan Keamanan

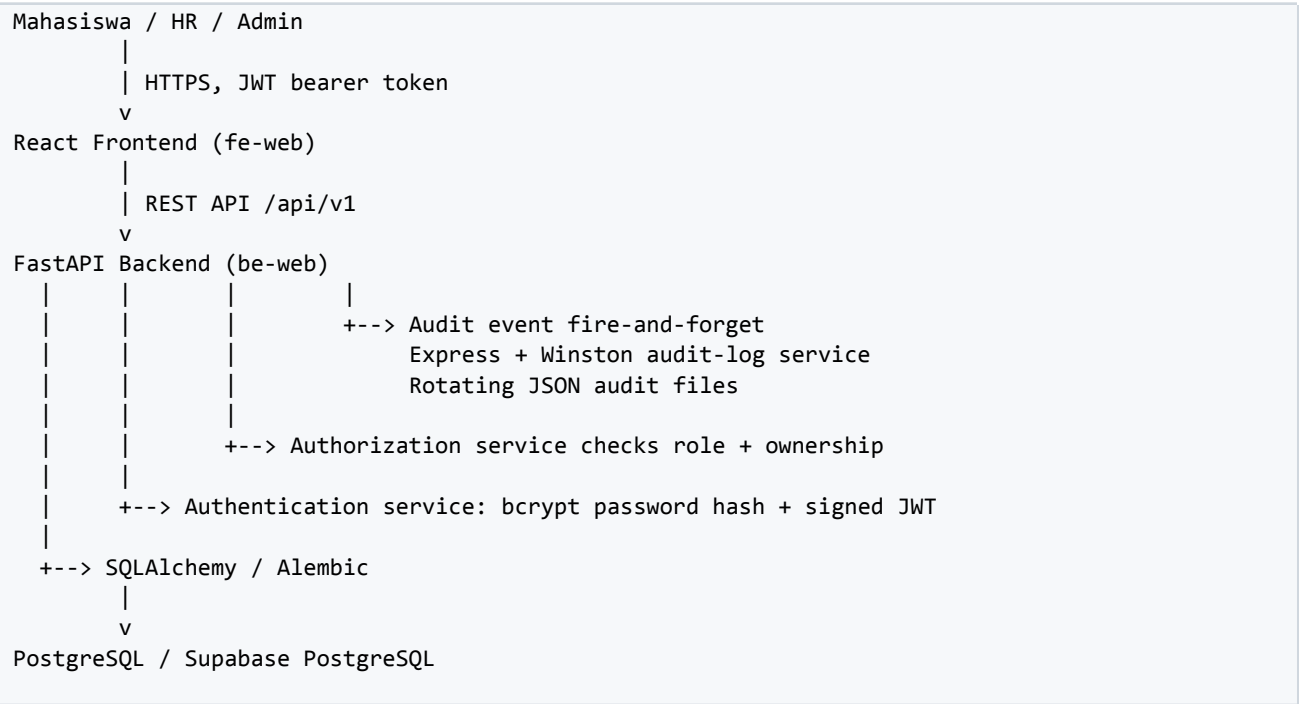
Dokumen desain keamanan untuk integrasi AAA, proteksi data, dan digital signature

Mata kuliah	KOM1315 Keamanan Informasi
Kelompok 9	Ghiffari Bravia Hisham - G6401231050 Adam Naufal - G6401231082 Rafif Muhammad Farras - G6401231102
Sistem	TUMBUH - Career & Internship Tracker

1. Ringkasan Rancangan

Dokumen ini menjelaskan rancangan keamanan TUMBUH sebagai aplikasi web Career & Internship Tracker. Rancangan berfokus pada pemisahan kontrol Authentication, Authorization, dan Accounting, serta perlindungan data sensitif mahasiswa, HR, perusahaan, dan admin platform.

2. Diagram Arsitektur Keamanan



3. Komponen dan Trust Boundary

Komponen	Tanggung jawab	Kontrol keamanan utama
React frontend	Antarmuka mahasiswa, HR, dan admin.	Menyimpan token hanya untuk request API; tidak menyimpan secret backend atau credential database.

FastAPI backend	Authentication, authorization, validasi input, business logic, dan akses database.	JWT validation, RBAC, ownership check, response filtering, rate limiting login/register.
PostgreSQL	System of record untuk users, companies, opportunities, applications, bookmarks, externships, resumes, dan notifications.	Akses hanya melalui backend; migration dikontrol Alembic; kolom sensitif diklasifikasikan.
Audit-log service	Menerima accounting event dari backend dan menulis JSON audit log.	Event tidak memuat password, token, private key, atau isi CV lengkap.
Key/config storage	Menyimpan SECRET_KEY, database URL, dan key material.	Environment variable atau secret manager; tidak dikomit ke repository.

4. Authentication Design

- Login menggunakan email dan password melalui endpoint auth backend.
- Password disimpan sebagai bcrypt hash pada kolom users.hash_password; plaintext password tidak pernah disimpan.
- Backend menerbitkan access token dan refresh token bertanda tangan HS256 dengan masa berlaku terbatas.
- Endpoint protected menggunakan OAuth2 bearer token dan menolak refresh token sebagai access token.
- Login dan register dibatasi rate limit 5 request per menit untuk mengurangi brute force.
- User mengirim email dan password ke /api/v1/auth/login.
- Backend mencari user berdasarkan email dan memverifikasi bcrypt hash.
- Jika valid dan akun aktif, backend menerbitkan access token dan refresh token.
- Backend mengirim audit event AUTH_LOGIN_SUCCESS atau AUTH_LOGIN_FAILURE.
- Frontend menyertakan access token pada request protected berikutnya.

5. Authorization Design

Role	Akses utama	Pembatasan
student	Profil sendiri, resume sendiri, bookmark sendiri, lamaran sendiri, submit application.	Tidak boleh mengakses endpoint HR/admin atau data mahasiswa lain.
hr	Kelola perusahaan sendiri, lowongan perusahaan sendiri, daftar pelamar dan status lamaran perusahaan sendiri.	Wajib company_id match pada operasi company, opportunity, dan application.
admin	Statistik platform, manajemen user, company, dan opportunity.	Akses luas harus tercatat sebagai audit event dan tidak boleh mengekspos secret.

- Role check dilakukan dengan dependency require_role pada backend.
- Ownership check dilakukan pada service sebelum operasi data lintas entitas, misalnya opportunity milik company HR.
- Client tidak boleh menentukan role efektif melalui request body; role diambil dari data user backend dan token yang tervalidasi.

6. Accounting dan Audit Logging

Accounting direalisasikan melalui service audit-log terpisah. Backend mengirim event secara fire-and-forget sehingga kegagalan audit service tidak memutus response utama, tetapi tetap dicatat secara lokal untuk observabilitas developer.

Kategori event	Contoh action	Prioritas
Authentication	AUTH_REGISTER, AUTH_LOGIN_SUCCESS, AUTH_LOGIN_FAILURE, AUTH_TOKEN_REFRESH	Tinggi
Applications	APPLICATION_SUBMIT, APPLICATION_STATUS_UPDATE, APPLICATION_BULK_STATUS_UPDATE	Tinggi
Opportunities	OPPORTUNITY_CREATE, OPPORTUNITY_UPDATE, OPPORTUNITY_DELETE	Sedang-Tinggi
Companies	COMPANY_CREATE, COMPANY_UPDATE, COMPANY_DELETE	Sedang-Tinggi
Users/Admin	USER_PROFILE_UPDATE, admin delete/toggle-active	Tinggi
System	RATE_LIMIT_EXCEEDED, UNHANDLED_ERROR	Sedang

7. Klasifikasi dan Proteksi Data

Data/kolom	Risiko	Rencana perlindungan
users.hash_password	Kompromi akun jika hash lemah atau bocor.	bcrypt hash + salt; jangan pernah return di API; secret rotation jika database bocor.
users.email, phone, nim, gpa, bio, social_links	Kebocoran data pribadi dan akademik.	RBAC, ownership check, minimisasi response, kandidat field-level encryption untuk data berisiko tinggi.
users.cv_url dan resume_profiles.*_info	Kebocoran CV dan riwayat personal.	Protected file access, ownership check, kandidat enkripsi dokumen/field JSON.
applications.cover_letter dan history	Kebocoran lamaran dan manipulasi status.	Akses student-owner atau HR-company-owner; audit setiap update status.
SECRET_KEY, DATABASE_URL, signing keys	Kompromi token, database, atau signature.	Environment variable/secret manager; tidak dikomit; rotasi berkala.

8. Digital Signature Design

Digital signature digunakan untuk aksi yang membutuhkan integritas dan non-repudiation, terutama perubahan status lamaran dan aksi administratif berisiko tinggi.

- Backend membentuk canonical payload berisi actor_id, actor_role, action, resource, resource_id, timestamp, dan hash data perubahan.
- Payload ditandatangani dengan private key dari secret storage atau environment yang aman.
- Signature dan public key identifier disimpan bersama audit evidence atau metadata perubahan.
- Verifikasi signature dilakukan saat audit review atau sebelum menerima perubahan penting jika workflow memerlukannya.
- Hasil verifikasi dicatat sebagai audit event tanpa menyimpan private key.

9. Manajemen Kunci dan Komunikasi Aman

- Semua komunikasi user ke frontend dan frontend ke backend pada deployment menggunakan HTTPS.
- DATABASE_URL, SECRET_KEY, AUDIT_LOG_URL, dan key material digital signature disimpan di environment/secret manager.
- Frontend tidak boleh menyimpan database URL, Supabase password, service role key, atau private key.
- Private key tidak masuk repository dan diganti jika terjadi indikasi kebocoran.
- Audit log diperlakukan sebagai data sensitif operasional dan tidak untuk publik.

10. Acceptance Checklist

Kontrol	Kriteria diterima
Authentication	Login valid mendapat token; login salah ditolak; password hash tidak pernah terekspos.
Authorization	Student, HR, dan admin hanya dapat mengakses endpoint sesuai role dan ownership.
Accounting	Event penting menghasilkan audit record yang memuat actor, action, resource, timestamp, dan success flag.
Data protection	Kolom sensitif teridentifikasi dan tidak keluar melalui API yang tidak berwenang.
Digital signature	Aksi penting memiliki payload yang dapat ditandatangani dan diverifikasi.